ClaimClarity · Data backend architecture

Field	Value
Owner	*TODO: name / team*
Status	*TODO: Draft / In review / Approved*
Last reviewed	*TODO: YYYY-MM-DD*
Reviewers	*TODO: security, data platform, app team*
Diagram source	*TODO: link to canvas / draw.io source*
Related pages	*TODO: link to "ClaimClarity · Frontend & UI states" page · TODO: ADRs · TODO: runbooks*

> **Note:** Diagram images in this page are exports of the architecture canvas. Filenames are stable (`images/<slug>.png`); replace the files in place when the diagrams change.

Contents

TODO: insert Confluence Table of Contents macro here (levels 2–3).

---

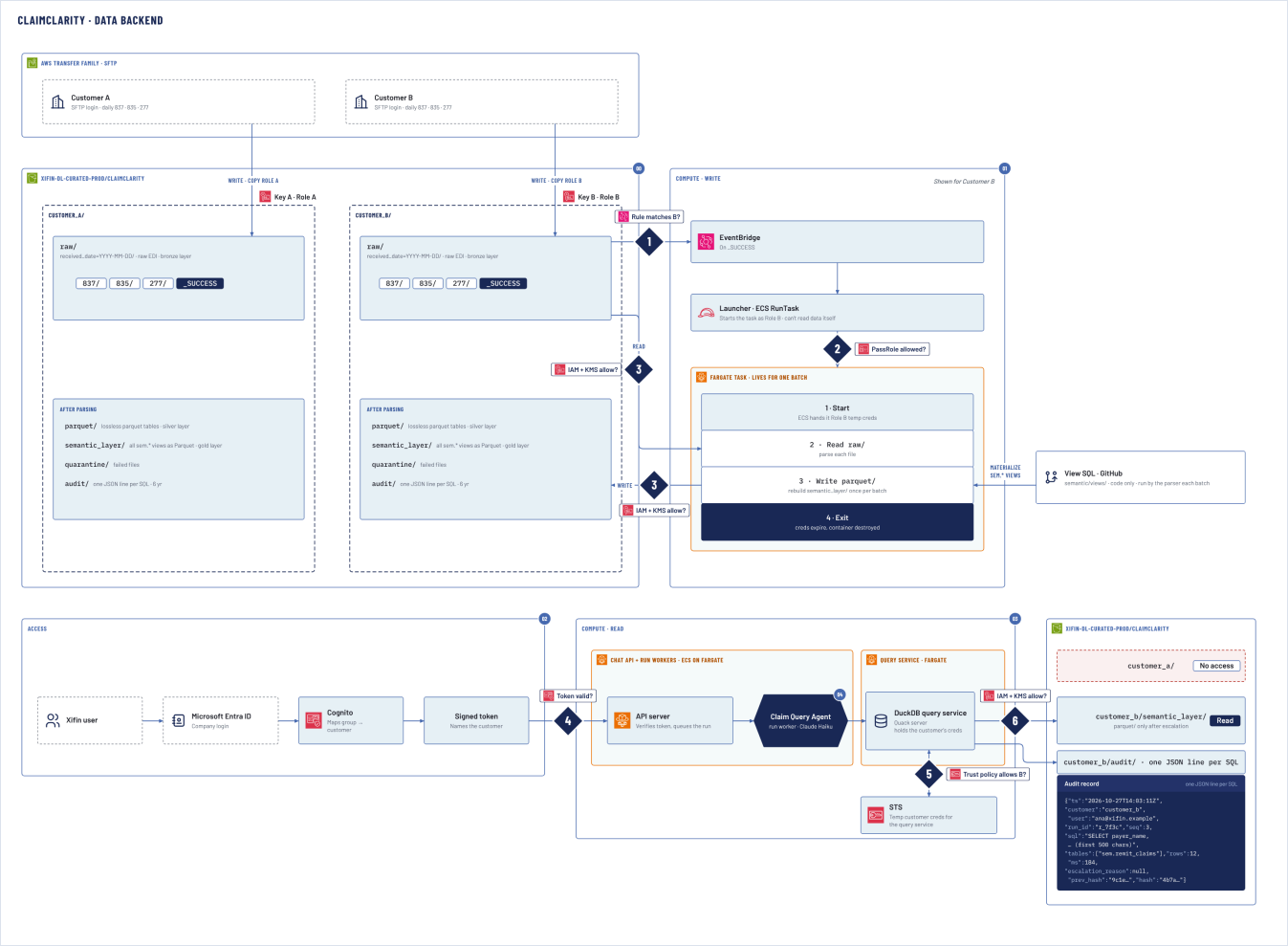
1. Purpose and audience

This page explains how customer claim data moves through the ClaimClarity backend and how each customer's data is kept isolated.

- **Purpose:** *TODO: what decisions / reviews this page supports (security review, onboarding, audit evidence).*
- **Audience:** *TODO: engineers, security reviewers, data platform, support.*
- **In scope:** *TODO: SFTP intake, S3 storage layout, parser, sign-in and customer mapping, query path, analyzer, IAM / KMS gates, audit.*
- **Out of scope:** *TODO: frontend / UI states (see the frontend page), cost, ops runbooks.*

2. Overview

The whole data backend on one board, shown for Customer B, with the six AWS gates and links to drill-downs 00–04.



TODO: caption — "Overview board, shown for Customer B."

2.1 How to read the diagrams

TODO: explain the legend — lanes (Compute · Write, Access, Compute · Read), numbered gate badges 1–6, write vs read arrows, "shown for Customer B" convention, drill-down numbers 00–05.

2.2 Main components at a glance

Component	Runs on	Role in the system
AWS Transfer Family (SFTP)	*TODO*	*TODO*
Data bucket `xifin-dl-curated-prod/claimclarity`	S3	*TODO*
EventBridge rule + launcher (ECS RunTask)	*TODO*	*TODO*
Fargate parser task	ECS on Fargate	*TODO*
View SQL (`semantic/views/`, GitHub)	*TODO*	*TODO*
Microsoft Entra ID	*TODO*	*TODO*
Amazon Cognito	*TODO*	*TODO*
Chat API + run workers	ECS on Fargate	*TODO*
Claim Query Agent (Claude Haiku)	Run worker	*TODO*
DuckDB query service (Quack server)	Fargate	*TODO*

Component	Runs on	Role in the system
AWS STS	*TODO*	*TODO*
KMS keys (one per customer)	KMS	*TODO*

2.3 End-to-end story

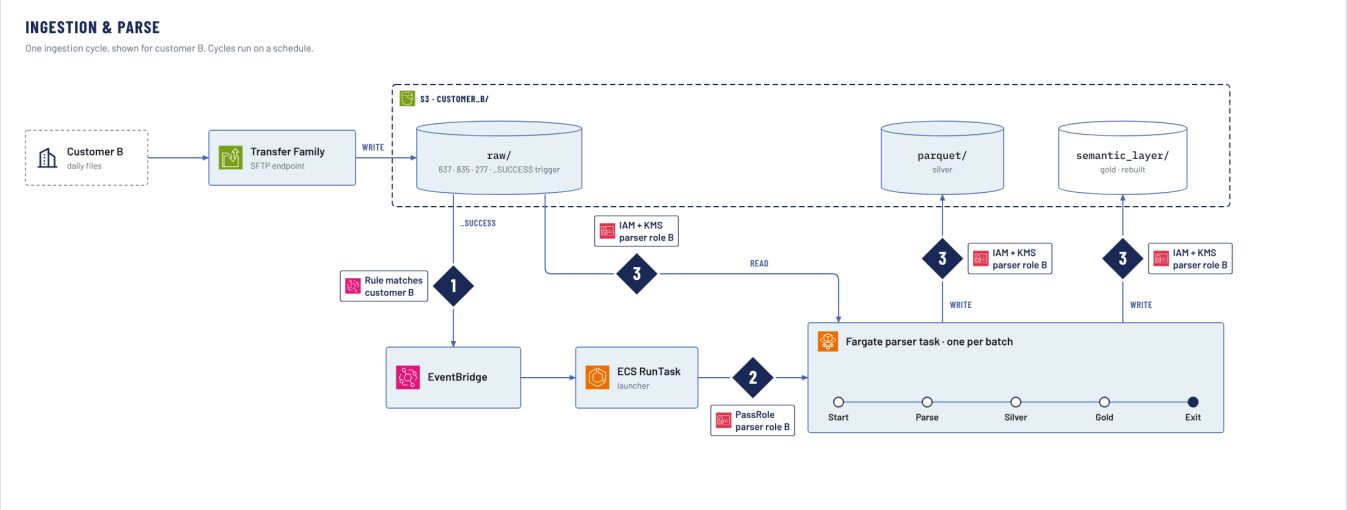
1. *TODO: customer drops daily 837 / 835 / 277 files over SFTP into* `raw/` *(→ section 3).*
2. *TODO: data at rest per customer prefix, layers and keys (→ section 4).*
3. *TODO: Xifin user signs in; token names one customer (→ section 5).*
4. *TODO: question goes to the analyzer / Claim Query Agent (→ section 7).*
5. *TODO: SQL runs in the DuckDB query service with one customer's temp creds (→ section 6).*
6. *TODO: every SQL is written to the customer's* `audit/` *(→ section 10).*

> **Note:** Sections follow the data story (intake → storage → login → query → analyzer → access matrix), not the diagram numbering.

---

3. Ingestion & parse (01)

One ingestion cycle for Customer B: files arrive over SFTP into `raw/`, the `_SUCCESS` marker triggers one Fargate parser task that writes silver and publishes a new gold version.



TODO: caption — "01 · Ingestion & parse, one cycle for Customer B."

3.1 What it shows

TODO: describe the scope of one ingestion cycle and the schedule it runs on.

3.2 Components

- **Customer B (daily files):** *TODO: file types 837 / 835 / 277, cadence, SFTP login.*
- **Transfer Family SFTP endpoint:** *TODO: per-customer login, SFTP copy role, write-once into* `raw/`.

- `raw/` **(bronze):** *TODO:* `received_date=YYYY-MM-DD/` *partitioning,* `837/ 835/ 277/` *subfolders,* `_SUCCESS` *marker.*
- **EventBridge rule:** *TODO: one rule per customer, matches* `_SUCCESS`*.*
- **Launcher (ECS RunTask):** *TODO: starts the task as parser role B; cannot read data itself.*
- **Fargate parser task:** *TODO: one task per batch, lifetime, image, sizing.*
- `parquet/` **(silver) and** `semantic_layer/` **(gold):** *TODO: outputs; see section 4.*

3.3 Flow / steps

1. **Start:** *TODO: ECS hands the task parser role B temp creds.*
2. **Parse:** *TODO: read each file in* `raw/`*, parse EDI.*
3. **Silver:** *TODO: write lossless parquet tables to* `parquet/`*; failed files to* `quarantine/`*.*
4. **Gold:** *TODO: run the* `sem.*` *view SQL from* `semantic/views/` *and publish a new* `semantic_layer/` *version once per batch.*
5. **Exit:** *TODO: creds expire, container destroyed.*

3.4 Security gates

Gate	Check	Where it applies
1	Rule matches customer B?	*TODO: EventBridge rule*
2	PassRole allowed for parser role B?	*TODO: launcher IAM policy*
3	IAM + KMS allow parser role B?	*TODO: each read of* `raw/` *and write to* `parquet/` */* `semantic_layer/`

3.5 Failure handling

TODO: what happens on parse failure (`quarantine/`*), missing* `_SUCCESS`*, partial batches, retries, alerting.*

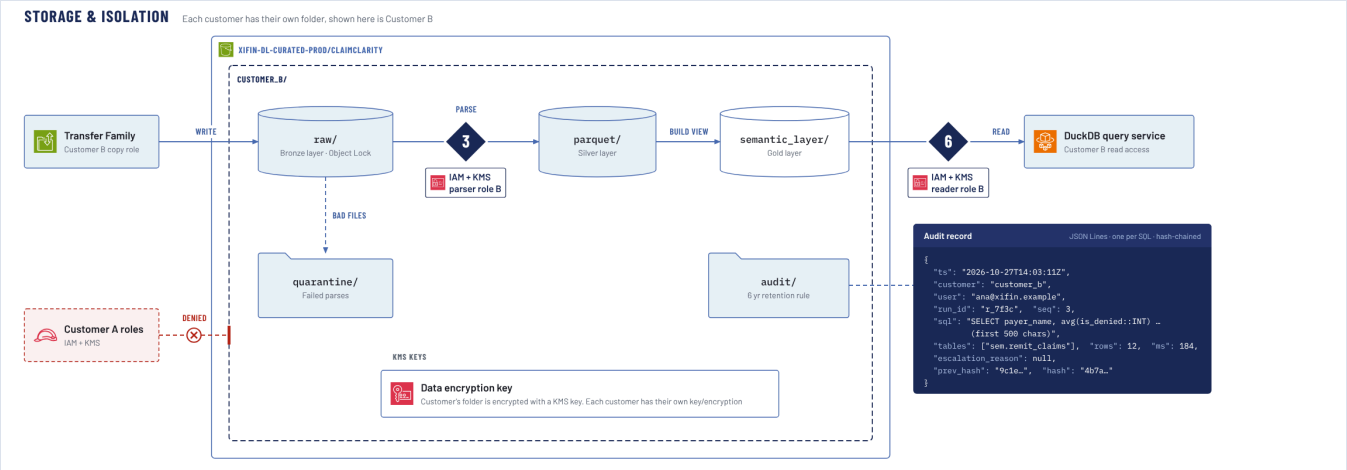
3.6 Open questions

- *TODO*

---

4. Storage & isolation (00)

Customer B's prefixes in the single ClaimClarity data bucket, the roles and KMS keys that guard them, and Customer A's roles being denied.



TODO: caption — "00 · Storage & isolation, Customer B's folder."

4.1 What it shows

TODO: one bucket, one folder per customer, one KMS key per customer.

4.2 Bucket and prefix layout

Prefix	Layer	Contents	Written by	Read by	Retention / protection
`customer_b/raw/`	Bronze	*TODO: raw EDI*	*TODO*	*TODO*	*TODO: Object Lock*
`customer_b/quarantine/`	—	*TODO: failed parses*	*TODO*	*TODO*	*TODO*
`customer_b/parquet/`	Silver	*TODO: lossless parquet tables*	*TODO*	*TODO: only after escalation*	*TODO*
`customer_b/semantic_layer/`	Gold	*TODO: all `sem.*` views as Parquet, versioned*	*TODO*	*TODO*	*TODO*
`customer_b/audit/`	—	*TODO: one JSON line per SQL, hash-chained*	*TODO*	*TODO*	*TODO: 6-year retention rule*

4.3 Encryption keys

TODO: one KMS key per customer; key policy; who can encrypt vs decrypt; rotation.

4.4 Roles per customer

- **Customer B copy role (Transfer Family):** *TODO*
- **Parser role B:** *TODO*
- **Reader role B (DuckDB query service):** *TODO*
- **Audit role:** *TODO*

4.5 Isolation between customers

TODO: why Customer A's roles are denied on `customer_b/` (IAM + KMS), and what an accidental cross-customer request looks like.

4.6 Security gates

Gate	Check	Role
3	IAM + KMS allow?	Parser role B
6	IAM + KMS allow?	Reader role B

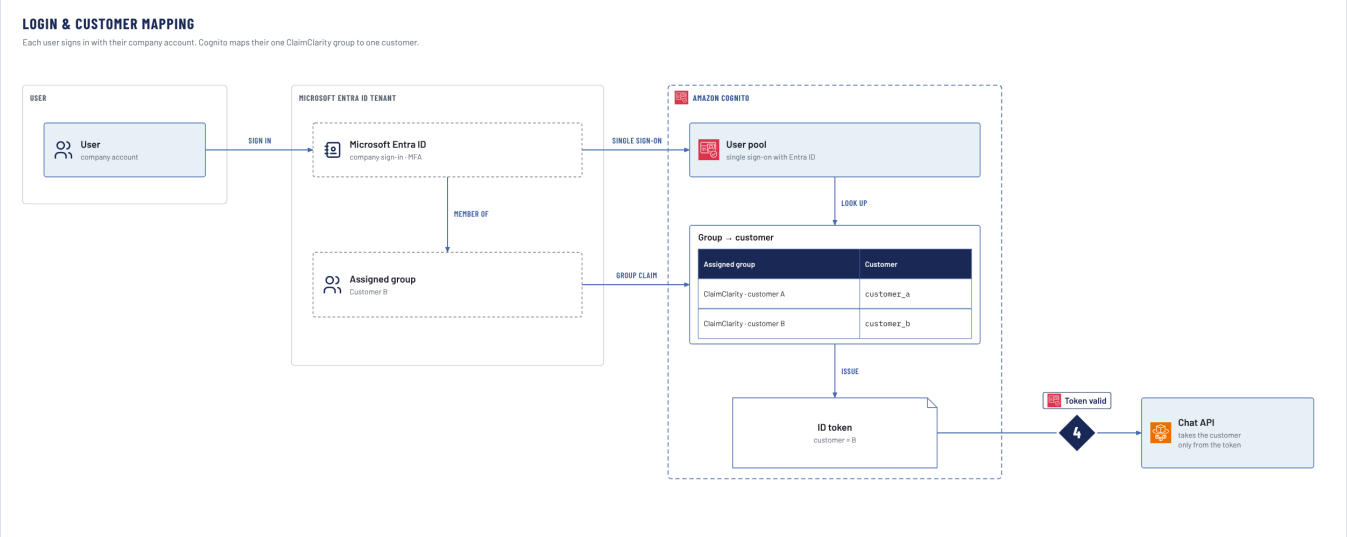
4.7 Open questions

- *TODO*

---

5. Login & customer mapping (02)

Each user signs in with their company account at Microsoft Entra ID; Cognito maps their one ClaimClarity group to exactly one customer and issues a token naming that customer.



TODO: caption — "02 · Login & customer mapping."

5.1 What it shows

TODO: describe sign-in from the user's company account to a token the Chat API trusts.

5.2 Components

- **User (company account):** *TODO*
- **Microsoft Entra ID tenant:** *TODO: company sign-in, MFA, assigned groups.*
- **Amazon Cognito user pool:** *TODO: SSO with Entra ID, group → customer lookup table.*
- **Chat API:** *TODO: takes the customer only from the token.*

5.3 Flow / steps

1. **Sign in:** *TODO*
2. **Member of:** *TODO: user's one assigned ClaimClarity group.*

3. **Single sign-on:** *TODO: Entra ID → Cognito.*
4. **Group claim:** *TODO*
5. **Look up:** *TODO: group → customer mapping.*
6. **Issue:** *TODO: ID token with* `customer = B`.

5.4 Group → customer mapping

Entra ID group	Customer
ClaimClarity · customer A	`customer_a`
ClaimClarity · customer B	`customer_b`

TODO: who owns this mapping, how a new customer is added, what happens with zero or multiple groups.

5.5 Security gates

Gate	Check	Defined in
4	Token valid and names the customer?	*TODO: Chat API, Cognito signature check on every request*

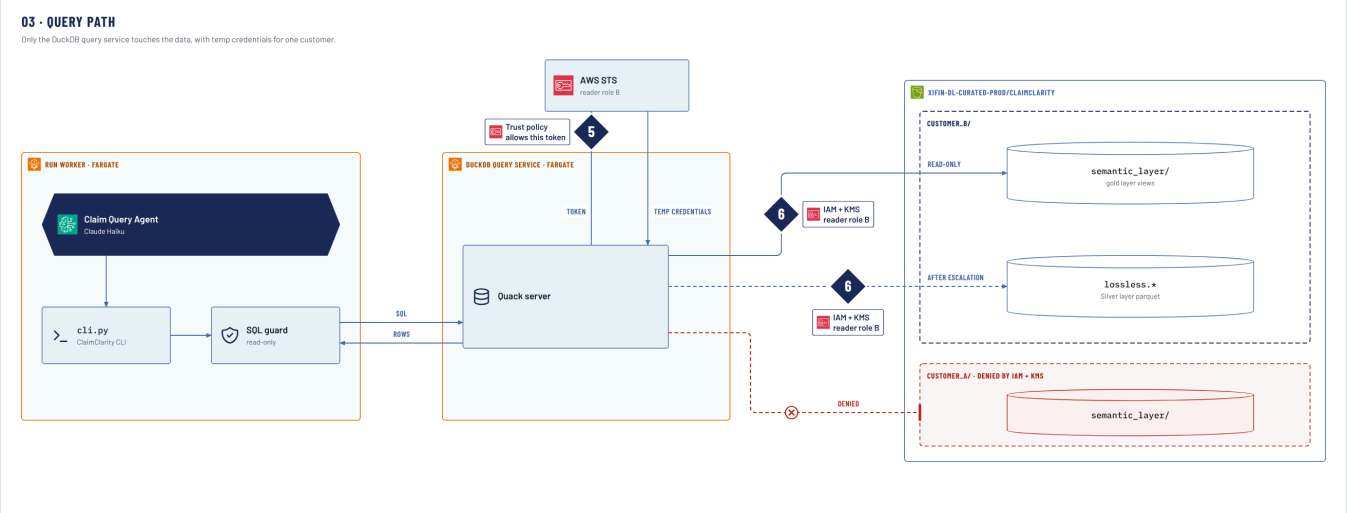
5.6 Open questions

- *TODO*

---

6. Query path (03)

The run worker sends SQL over Quack to the DuckDB query service, which alone exchanges the token at STS for customer B's 15-minute credentials and reads only customer B's data.



TODO: caption — "03 · Query path, Customer B."

6.1 What it shows

TODO: only the DuckDB query service touches data, with temp credentials for one customer.

6.2 Components

- **Run worker (Fargate):** *TODO: hosts the Claim Query Agent, cli.py, SQL guard; holds no data credentials.*
- **DuckDB query service (Fargate):** *TODO: Quack server, holds the customer's temp creds.*
- **AWS STS:** *TODO: token exchange for reader role B.*
- `customer_b/semantic_layer/` **(gold) and** `lossless.*` **(silver parquet):** *TODO*

6.3 Flow / steps

1. **SQL:** *TODO: run worker → Quack server.*
2. **Token:** *TODO: query service presents the user's token to STS.*
3. **Temp credentials:** *TODO: 15-minute creds for reader role B.*
4. **Read-only:** *TODO: read gold views; silver* `lossless.*` *only after escalation.*
5. **Rows:** *TODO: results streamed back to the run worker.*

6.4 Security gates

Gate	Check	Defined in
5	Trust policy allows this token's customer?	*TODO: reader role trust policy (STS)*
6	IAM + KMS allow reader role B?	*TODO: reader role IAM policy, customer key policy*

6.5 Cross-customer denial

TODO: describe how a request for `customer_a/` *is denied by IAM + KMS even if SQL asked for it.*

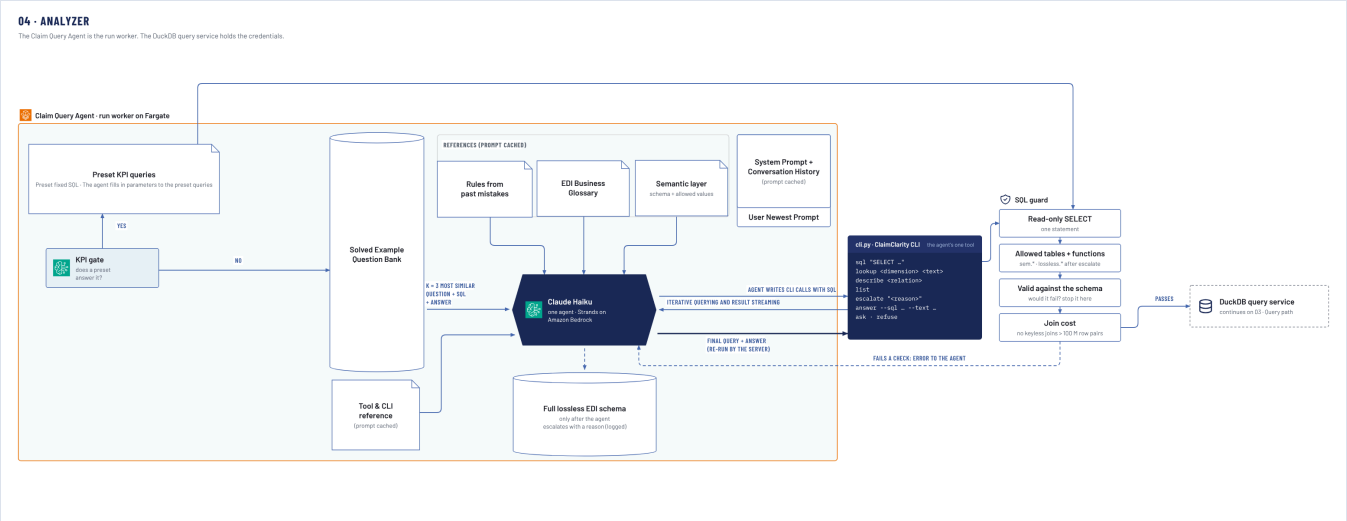
6.6 Open questions

- *TODO*

---

7. Analyzer (04)

The KPI gate answers with a preset query or hands the question to the Claim Query Agent, which writes SQL through cli.py and the SQL guard; the query then continues on the query path (section 6).



TODO: caption — "04 · Analyzer."

7.1 What it shows

TODO: how a user question becomes validated SQL and an answer.

7.2 KPI gate

TODO: "does a preset answer it?" — yes: preset fixed SQL with parameters filled in by the agent; no: hand to the agent.

7.3 Claim Query Agent

TODO: one agent, Claude Haiku, Strands on Amazon Bedrock; runs as the run worker on Fargate; inputs = system prompt + conversation history (prompt cached) + newest user prompt.

7.4 References (prompt cached)

- **Preset KPI queries:** *TODO*
- **Solved examples / question bank:** *TODO: K = 3 most similar question + SQL + answer.*
- **Tool & CLI reference:** *TODO*
- **Rules from past mistakes:** *TODO*
- **EDI business glossary:** *TODO*
- **Semantic layer schema + allowed values:** *TODO*
- **Full lossless EDI schema:** *TODO: only after the agent escalates with a logged reason.*

7.5 cli.py · ClaimClarity CLI

Command	Purpose
`sql "SELECT …"`	*TODO*
`lookup <dimension> <text>`	*TODO*
`describe <relation>`	*TODO*
`list`	*TODO*

Command	Purpose
`escalate "<reason>"`	*TODO*
`answer --sql … --text …`	*TODO: final query re-run by the server*
`ask` · `refuse`	*TODO*

7.6 SQL guard checks

1. **Read-only SELECT, one statement:** *TODO*
2. **Allowed tables + functions:** *TODO:* `sem.*`; `lossless.*` *only after escalate.*
3. **Valid against the schema:** *TODO: would it fail? stop it here.*
4. **Join cost:** *TODO: no keyless joins over 100 M row pairs.*

TODO: on failure, the error goes back to the agent; on pass, continue to section 6.

7.7 Iterative querying and answer

TODO: iterative querying and result streaming; final query + answer re-run by the server.

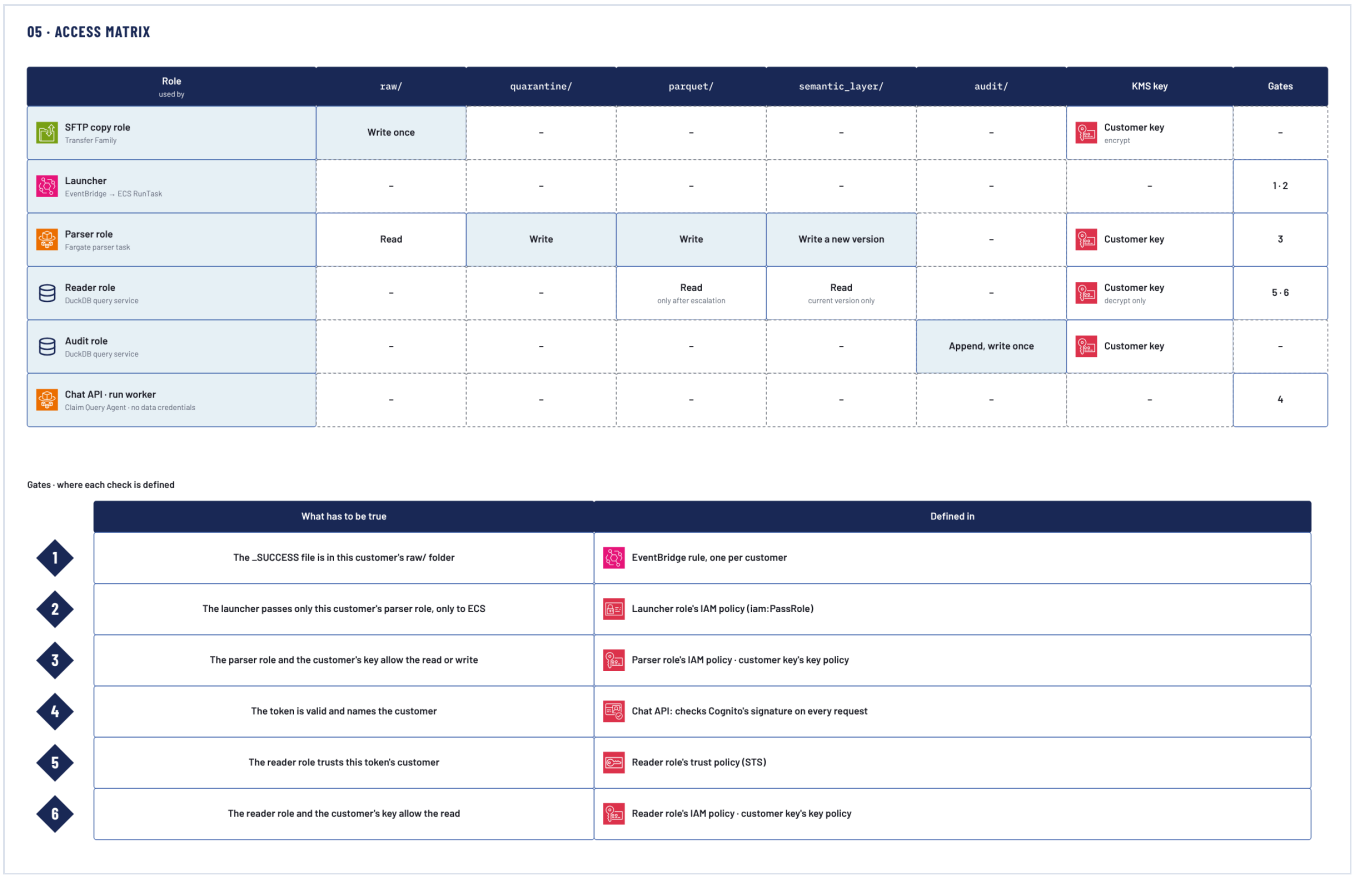
7.8 Open questions

- *TODO*

---

8. Access matrix (05)

What each role can do in each customer prefix, the key it uses and the gates that guard it, plus where each of the six gates is defined.



TODO: caption — "05 · Access matrix."

8.1 Roles × prefixes

Role	Used by	raw/	quarantine/	parquet/	semantic_layer/	audit/	KMS key	Gates
SFTP copy role	Transfer Family	*TODO*					*TODO*	
Launcher	EventBridge → ECS RunTask							*TODO*
Parser role	Fargate parser task	*TODO*	*TODO*	*TODO*	*TODO*		*TODO*	*TODO*
Reader role	DuckDB query service			*TODO*	*TODO*		*TODO*	*TODO*
Audit role	DuckDB query service					*TODO*	*TODO*	
Chat API · run worker	Claim Query Agent						*TODO: none*	*TODO*

TODO: fill from the diagram; keep in sync with the PNG.

8.2 Gates · where each check is defined

See section 9 for the consolidated gate table.

8.3 Open questions

- *TODO*

---

9. Security & isolation model

Customer isolation rests on six gates; each must pass for a request to touch one customer's data.

#	What has to be true	Defined in	Diagram(s)
1	*TODO: `_SUCCESS` is in this customer's `raw/`*	*TODO: EventBridge rule, one per customer*	01, main
2	*TODO: launcher passes only this customer's parser role, only to ECS*	*TODO: launcher IAM policy (`iam:PassRole`)*	01, main
3	*TODO: parser role + customer key allow the read/write*	*TODO: parser role IAM policy, key policy*	00, 01, main
4	*TODO: token is valid and names the customer*	*TODO: Chat API Cognito signature check*	02, main
5	*TODO: reader role trusts this token's customer*	*TODO: reader role trust policy (STS)*	03, main
6	*TODO: reader role + customer key allow the read*	*TODO: reader role IAM policy, key policy*	00, 03, main

9.1 Write side (gates 1–3)

TODO: summarise how ingestion is confined to one customer.

9.2 Read side (gates 4–6)

TODO: summarise how queries are confined to one customer; the agent holds no data credentials.

9.3 Defence in depth beyond the gates

TODO: SQL guard, escalation logging, Object Lock on `raw/`, short-lived credentials, per-customer KMS keys.

9.4 Threats considered

TODO: link or list threat-model items (prompt injection, cross-customer SQL, stolen token, misrouted file).

10. Audit

Every SQL statement is recorded as one hash-chained JSON line in the customer's `audit/` prefix.

10.1 Audit record format

```
{
  "ts": "2026-10-27T14:03:11Z",
  "customer": "customer_b",
  "user": "ana@xifin.example",
  "run_id": "r_7f3c", "seq": 3,
  "sql": "SELECT payer_name, … (first 500 chars)",
  "tables": ["sem.remit_claims"], "rows": 12, "ms": 184,
  "escalation_reason": null,
  "prev_hash": "9c1e…", "hash": "4b7a…"
}
```

TODO: field definitions, hash-chain verification.

10.2 Writer, retention and access

TODO: audit role (append, write once), 6-year retention rule, who can read audit logs.

10.3 Open questions

- *TODO*

11. Glossary

Term	Meaning
837 / 835 / 277	*TODO: EDI claim / remittance / claim status transactions*
Bronze / silver / gold	*TODO:* `raw/` / `parquet/` / `semantic_layer/`
`sem.*`	*TODO*
`lossless.*`	*TODO*
`_SUCCESS`	*TODO*
Escalation	*TODO*
KPI gate	*TODO*
Quack	*TODO*
Run worker	*TODO*
TODO: more	

12. Decision log / ADRs

Decision	Status	Link
TODO: one bucket with per-customer prefixes and KMS keys	*TODO*	*TODO*

Decision	Status	Link
TODO: only the DuckDB query service holds data credentials	*TODO*	*TODO*
TODO: one Fargate parser task per batch	*TODO*	*TODO*
TODO: Entra ID → Cognito group-to-customer mapping	*TODO*	*TODO*
TODO: single agent on Claude Haiku with one CLI tool	*TODO*	*TODO*

13. Open questions

#	Question	Owner	Status
1	*TODO*	*TODO*	*TODO*

14. Change history

TODO: version, date, author, summary of change; note when diagram PNGs are replaced.